

Emulated Trust

Un autre challenge de la catégorie reverse fournissait un exécutable linux nommé `bs_emulated_trust`.

Résolution du challenge

On ouvre le fichier dans Ghidra. Le main appelle plusieurs fonctions. L'une d'entre elles, `bs_initialize_environment`, vérifie que la fonction n'est pas débuggée grâce à 3 checks différents : `ptrace`, `/proc/self/status` et `getenv("LD_PRELOAD")`. Dans le cas contraire, elle arrête le programme.

```
2 void bs_initialize_environment(void)
3
4 {
5     int iVar1;
6     FILE *__stream;
7     char *pcVar2;
8     long lVar3;
9     char acStack_118 [10];
10    undefined1 local_10e [254];
11
12    __stream = fopen64("/proc/self/status","r");
13    if (__stream != (FILE *)0x0) {
14        do {
15            pcVar2 = fgets(acStack_118,0x100,__stream);
16            if (pcVar2 == (char *)0x0) {
17                fclose(__stream);
18                goto LAB_00102822;
19            }
20            iVar1 = strncmp(acStack_118,"TracerPid:",10);
21        } while (iVar1 != 0);
22        iVar1 = __isoc23_strtol(local_10e,0,10);
23        fclose(__stream);
24        if (iVar1 != 0) goto LAB_0010280b;
25    }
26 LAB_00102822:
27    lVar3 = ptrace(PTRACE_TRACEME,0,1,0);
28    if ((lVar3 != -1) && ((pcVar2 = getenv("LD_PRELOAD"), pcVar2 == (char *)0x0 || (*pcVar2 == '\0'))))
29        {
30            return;
31        }
32 LAB_0010280b:
33    bs_denied();
34    /* WARNING: Subroutine does not return */
35    _exit(1);
36 }
```

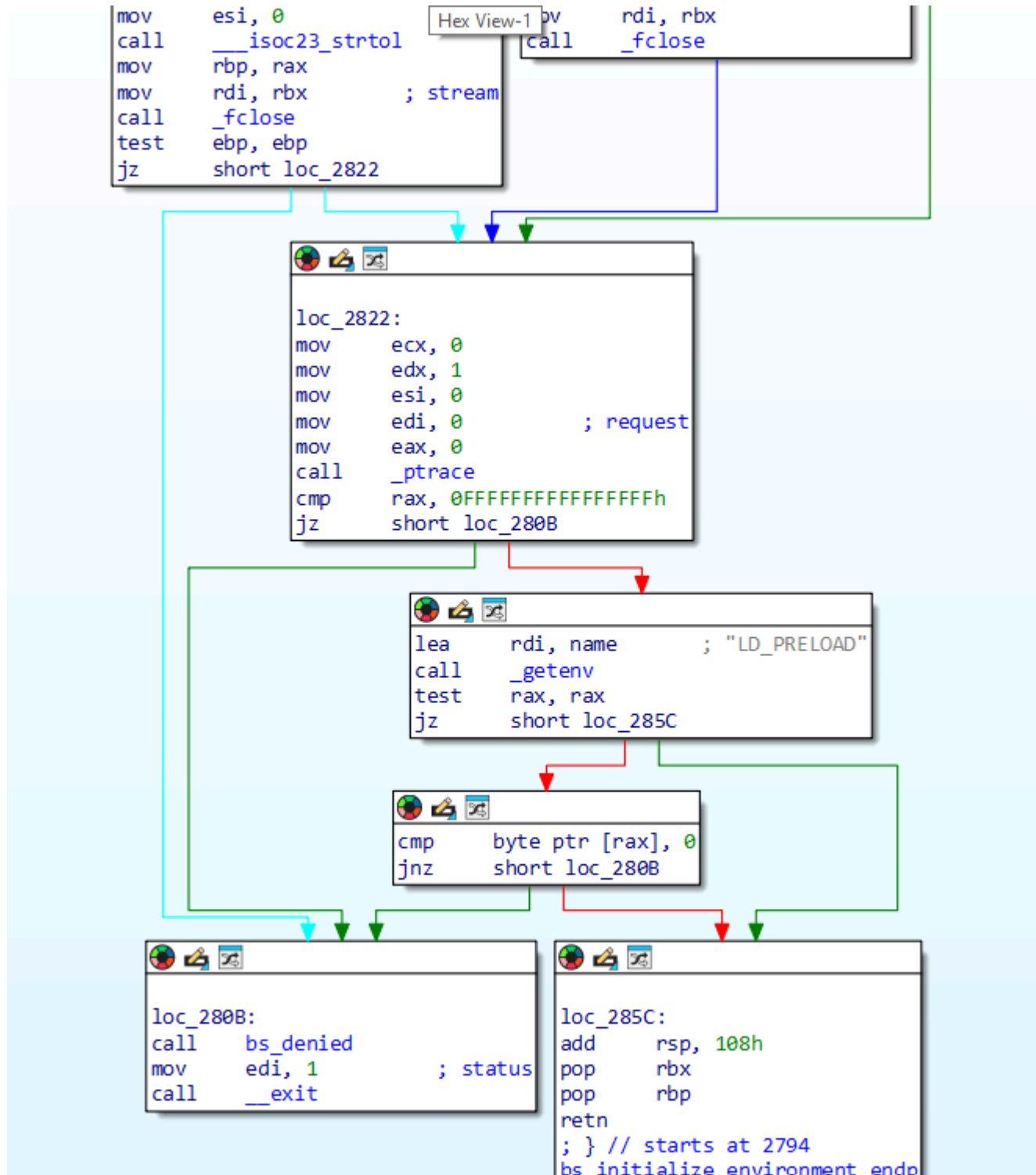
Le main appelle aussi `bs_validate_input` qui vérifie si la chaîne entrée est correcte et fait 37 caractères. Pour chaque caractère, elle appelle `bs_decode_character` et compare le caractère retournée par la fonction avec celui écrit par l'utilisateur. `bs_decode_character` sert à décoder le caractère attendu.

```

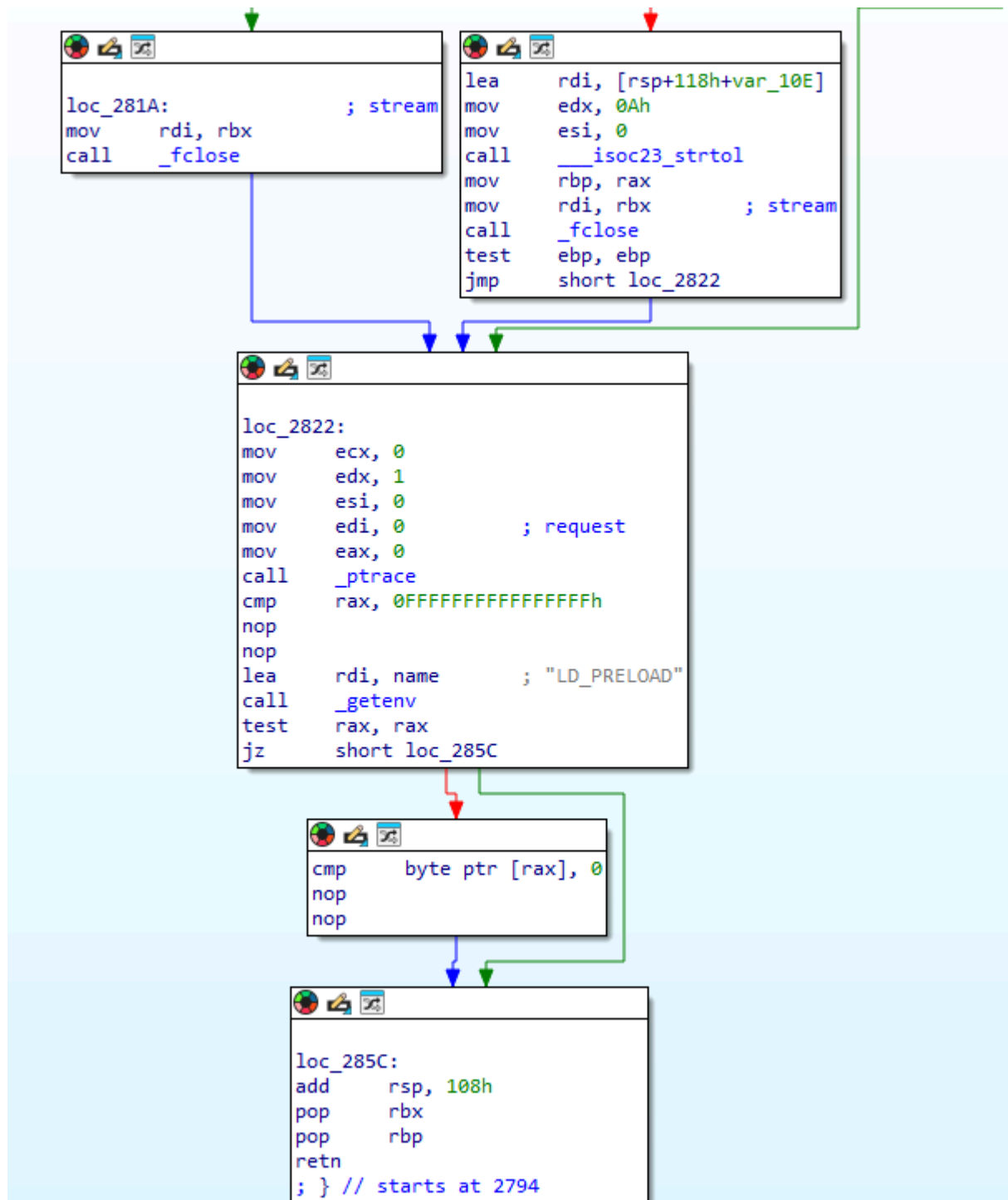
-----
cVar2 = bs_decode_character(&local_48);
if (cVar1 != cVar2) {
    return 0;
}
lVar7 = lVar7 + 1;
} while (lVar7 != 0x25);

```

Pour éviter de lire le code assembleur très obfusqué, les checks anti-debug sont patchés afin de pouvoir débiter.

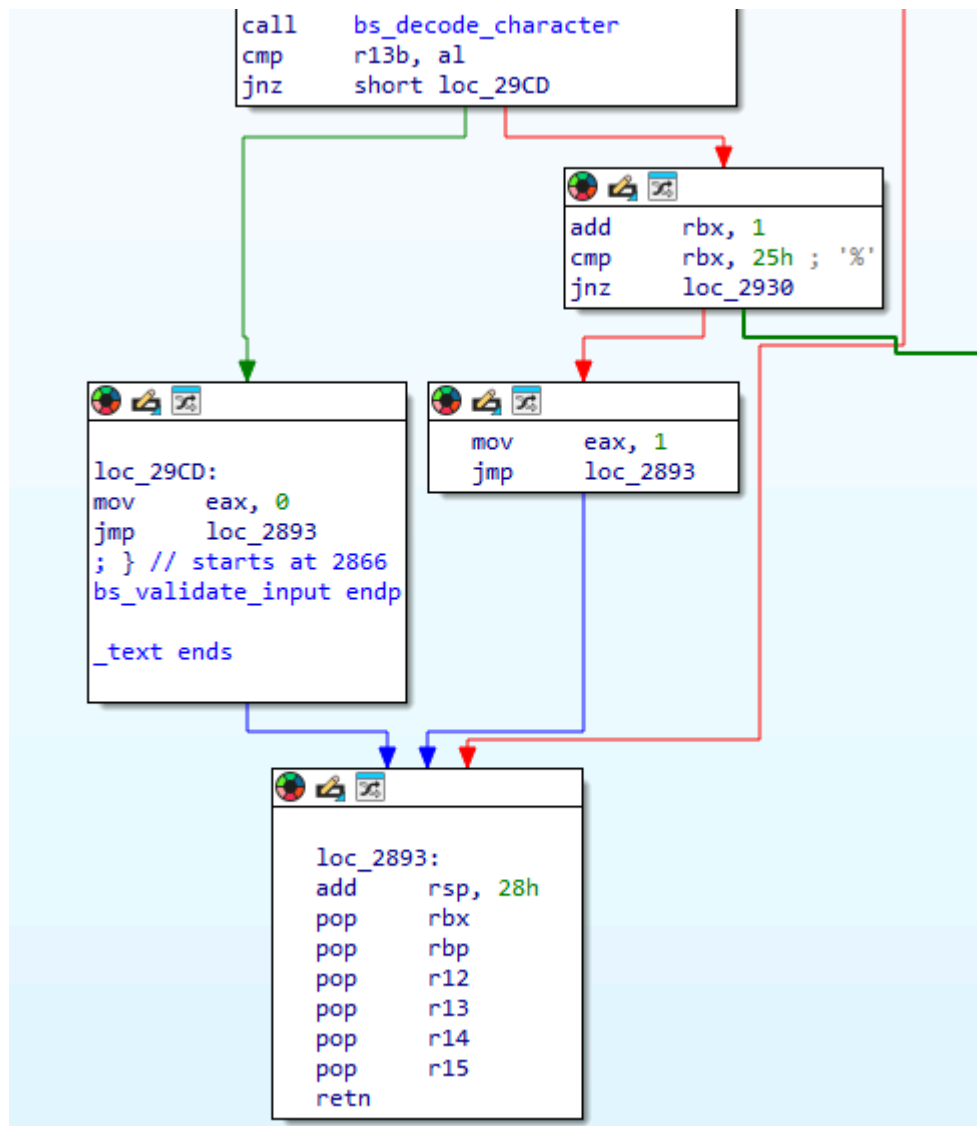


Les trois flèches allant sur le bloc appelant la fonction de refus `bs_denied` représente trois check d'anti debug.

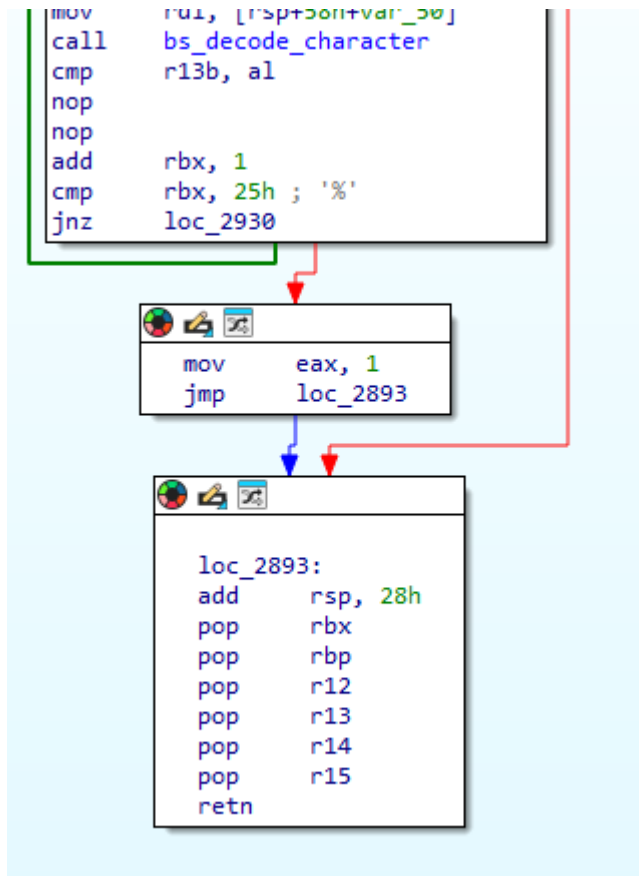


En passant d'un saut conditionnel à un saut inconditionnel ou en nopant les sauts pour que la fonction ne saute jamais à l'appel de `bs_denied`, la fonction peut enfin être débuggée sans prise de tête.

Pour pouvoir observer chaque caractère retourné par la fonction `bs_decode_character` lors du débuggage, la vérification individuelle de chaque caractère est également patchée afin de tout voir en un seul passage.



Avant.



Après.

Une fois cela fait, on lance le débogueur avec un point d'arrêt après chaque retour de la fonction `bs_decode_character` pour chaque `i`. À chaque arrêt sur un breakpoint, le contenu du registre `eax` est imprimé puis l'exécution continue.

```
(gdb) break *0x555555556468
Breakpoint 1 at 0x555555556468
(gdb) commands
Type commands for breakpoint(s) 1, one per line.
End with a line saying just "end".
>silent
>printf "char = 0x%02x '%c'\n", $eax, $eax
>continue
>end
(gdb) run
Starting program: /home/flupinette/4A-TP/rootme/ctf/bs_emulated_trust_patched
[Thread debugging using libthread_db enabled]
Using host libthread_db library "/lib/x86_64-linux-gnu/libthread_db.so.1".
Breizh Systems :: artifact emulated-trust
Breizh Systems :: enter token: aaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaa
char = 0x42 'B'
char = 0x5a 'Z'
char = 0x48 'H'
char = 0x43 'C'
char = 0x54 'T'
char = 0x46 'F'
char = 0x7b '{'
char = 0x35 '5'
char = 0x30 '0'
char = 0x6d 'm'
char = 0x33 '3'
char = 0x37 '7'
char = 0x31 '1'
char = 0x6d 'm'
char = 0x33 '3'
char = 0x35 '5'
char = 0x5f '_'
char = 0x33 '3'
char = 0x6d 'm'
char = 0x75 'u'
char = 0x31 '1'
char = 0x34 '4'
char = 0x37 '7'
char = 0x31 '1'
char = 0x30 '0'
char = 0x6e 'n'
char = 0x5f '_'
char = 0x31 '1'
char = 0x35 '5'
char = 0x5f '_'
char = 0x33 '3'
char = 0x34 '4'
char = 0x35 '5'
char = 0x31 '1'
char = 0x33 '3'
char = 0x72 'r'
char = 0x7d '}'
```

```
char = 0x7d }  
Breizh Systems :: status: ok
```

Le flag est BZHCTF{50m371m35_3mu14710n_15_34513r}!